CRISC Exam - Hard Questions with Explanations

From CRISC GPTs

Compiled from ISACA CRISC GPT APIs

October 25, 2026

Outline

1. Domain 1: IT Risk Identification
2. Domain 2: IT Risk Assessment
3. Domain 3: Risk Response and Mitigation
4. Domain 4: Risk and Control Monitoring
5. Domain 1: Additional Key Concepts
6. Domain 2: Additional Assessment Concepts
7. Domain 3: Additional Response Concepts
8. Domain 4: Additional Monitoring Concepts

Q1: Resilient Business Processes

Question

Which business requirement BEST relates to the need for resilient business and information systems processes?

A. Effectiveness
B. Confidentiality
C. Integrity
D. Availability

Q1: Explanation

Correct Answer: D

Availability relates to information being available when required by the business process now and in the future. Resilience is the ability to provide and maintain an acceptable level of service during disasters or when facing operational challenges.

Option Analysis

- **A - Incorrect:** Effectiveness deals with information being relevant and delivered timely
- **B - Incorrect:** Confidentiality deals with protection from unauthorized disclosure
- **C - Incorrect:** Integrity relates to accuracy and completeness
- **D - Correct:** Availability is directly linked to resilience

Q1: Resilient Business Processes

Question

Which business requirement BEST relates to the need for resilient business and information systems processes?

- A Effectiveness
- B Confidentiality
- C Integrity
- D Availability

Memory Aid

Confidentiality = Prevent Disclosure Integrity = Prevent Unauthorized Change Availability = Keep Systems Running Resilience = Availability During Disruption

Q1: Explanation

Correct Answer: D - Availability

Resilience is the ability of systems and business processes to continue operating or recover quickly following a disruption. This objective is most closely aligned with availability because information and services must remain accessible when required.

Option Analysis

A - Incorrect: Effectiveness Effectiveness focuses on whether information supports business objectives, decision-making, and operational needs. While an effective process may contribute to resilience, effectiveness does not specifically address continuity during disruptions. **B - Incorrect: Confidentiality** Confidentiality ensures information is protected from unauthorized disclosure. A highly confidential system can still be unavailable during an outage, making confidentiality different from resilience. **C - Incorrect: Integrity** Integrity ensures information remains accurate, complete, and authorized. Although integrity is critical, resilience focuses on maintaining service availability rather than preventing unauthorized modification. **D - Correct: Availability** Availability ensures systems, data, and services remain accessible when needed. Disaster recovery, business continuity, fault tolerance, redundancy, and resiliency initiatives are all primarily intended to support availability.

Q2: Value of Risk Register

Question

Which statement BEST describes the value of a risk register?

A. It captures the risk inventory

B. It drives the risk response plan

C. It is a risk reporting tool

D. It lists internal risk and external risk

Memory Aid

Risk Assessment = Identify Risks Risk Register = Record Risks Risk Owner = Own the Risk Risk Register = Prioritize Risks Risk Response Plan = Treat Risks Reports/Dashboards = Communicate Risks Think:

"No Register = No Prioritization" "No Prioritization = No Risk Response"

Q2: Explanation

Correct Answer: B - It Drives the Risk Response Plan

A risk register is the central repository for risk information. It documents risk descriptions, likelihood, impact, ownership, treatment strategies, and residual risk. Its greatest value is enabling management to prioritize and respond to risks in a consistent manner.

Option Analysis

A - Incorrect: It Captures the Risk Inventory A risk register does maintain an inventory of identified risks. However, simply listing risks provides little value unless the information is used to determine ownership, prioritization, treatment, and monitoring activities. **B - Correct: It Drives the Risk Response Plan** Risk response decisions are based on the information contained within the risk register. Management uses risk ratings, ownership assignments, treatment status, and residual risk information to determine how risks should be addressed. **C - Incorrect: It Is a Risk Reporting Tool** Risk reports and dashboards may be generated from the risk register, but the register itself is primarily a repository and management tool rather than a reporting mechanism. **D - Incorrect: It Lists Internal Risk and External Risk** A risk register may contain both internal and external risks, but this is merely one attribute of the information

Q3: New Law Impact on HR System

Question

Shortly after annual policy review, a new law may affect security requirements for HR system. Risk practitioner should:

- (A) Analyze how the law may affect the enterprise
- (B) Ensure adjustments during next review cycle
- (C) Initiate an ad hoc revision of corporate policy
- (D) Notify system custodian to implement changes

Q3: Explanation

Correct Answer: A

Assessing how the law may affect the enterprise is the best course of action. The analysis must also determine whether existing controls already address the new requirements.

Option Analysis

- **A - Correct:** Analysis is the first step
- **B - Incorrect:** Significant changes should trigger ad hoc reassessment
- **C - Incorrect:** Policy should be developed systematically
- **D - Incorrect:** Changes need approval by process owner

Q3: Regulatory Change Impact

Question

Shortly after the annual risk assessment is completed, a new privacy regulation is enacted that may affect several business processes involving employee information. Senior management asks the risk practitioner how the organization should respond. What should the risk practitioner do FIRST?

A. Assess the impact of the regulation on business processes and existing controls
B. Initiate an immediate update to all security policies
C. Direct system owners to implement new controls
D. Wait until the next scheduled review cycle

CRISC Exam Tip

New Law → Impact Assessment → Gap Analysis → Policy/Control Updates → Implementation When asked what to do FIRST, choose the answer involving assessment, analysis, or understanding the situation.

Q3: Explanation

Correct Answer: A

Before modifying policies, controls, or systems, management must first understand how the regulatory change affects the organization. The impact assessment determines whether changes are required and whether existing controls already satisfy the new requirements.

Option Analysis

A - **Correct** Impact analysis is the appropriate first step. CRISC questions frequently test the principle that risk practitioners should assess before acting. Regulatory changes do not automatically require policy or control changes. **B** - **Incorrect** Policies may

eventually require revision, but updating policies before understanding the impact could create unnecessary work or introduce requirements that are not needed. **C** - **Incorrect**

Control implementation should occur only after management understands the regulatory requirements and determines which gaps actually exist. **D** - **Incorrect** Significant

regulatory changes may require action before the next review cycle. Deferring analysis could expose the organization to compliance risk.

Q4: Weather Forecast System Priority

Question

An information system that processes weather forecasts for public consumption is MOST likely to place its highest priority on:

A. Nonrepudiation
B. Confidentiality
C. Integrity
D. Availability

Q4: Explanation

Correct Answer: C

A system that delivers weather forecasts is likely to place its highest priority on the integrity of the data. The risk practitioner should keep in mind that whether a forecast turns out to be accurate in its prediction is distinct from whether the data was accurately represented.

Option Analysis

- **A - Incorrect:** Nonrepudiation is unlikely to be important for weather forecasts
- **B - Incorrect:** Keeping data confidential would be at odds with public use
- **C - Correct:** Integrity of data is paramount
- **D - Incorrect:** Availability is important but integrity is higher priority

Q4: Weather Forecast System Priority

Question

An information system distributes weather forecasts to the public. Which information security objective should receive the HIGHEST priority?

- A Nonrepudiation
- B Confidentiality
- C Integrity
- D Availability

CRISC Memory Aid

Weather Forecast = Integrity Emergency Services = Availability Medical Records = Confidentiality + Integrity Contracts/Digital Signatures = Nonrepudiation

Q4: Explanation

Correct Answer: C - Integrity

The value of a weather forecasting system depends on the accuracy and reliability of the information being presented. If forecast data is altered, corrupted, or incorrectly displayed, the public could make poor decisions based on inaccurate information. Therefore, integrity is the most important objective.

Option Analysis

A - Incorrect: Nonrepudiation Nonrepudiation provides proof that a specific party performed an action or submitted information. This requirement is far more important in areas such as contracts, financial transactions, and digital signatures than in public weather forecasting. **B - Incorrect: Confidentiality** Weather forecasts are intended for public consumption. Restricting access to the information would not support the organization's mission. **C - Correct: Integrity** Forecasts must be presented accurately and without unauthorized modification. Users depend on the correctness of the information, even if the prediction itself later proves inaccurate. Integrity focuses on ensuring the data has not been improperly altered. **D - Incorrect: Availability**

Availability is certainly important because users need access to forecasts when severe weather is approaching. However, an available system that provides incorrect

Q5: Best Risk Management View

Question

Which provides the BEST view of risk management?

- A. An interdisciplinary team
- B. A third-party risk assessment
- C. IT department risk assessment
- D. Internal compliance department

Q5: Explanation

Correct Answer: A

Having an interdisciplinary team contribute to risk management ensures that all areas are adequately considered and included in the risk assessment processes to support an enterprise view of risk.

Option Analysis

- **A - Correct:** Interdisciplinary team provides enterprise-wide view
- **B - Incorrect:** Without internal knowledge, assessment adequacy is difficult
- **C - Incorrect:** IT department unlikely to reflect entire enterprise
- **D - Incorrect:** Compliance department focuses on regulatory implications

Q5: Enterprise Risk View

Question

Executive management wants to obtain the most comprehensive view of enterprise risk before approving a major technology transformation initiative. Which approach would BEST support this objective?

- (A) Conduct a risk assessment using representatives from business, IT, legal, compliance, and operations
- (B) Rely on an independent third-party risk assessment
- (C) Obtain an IT risk assessment from the technology department
- (D) Request a review from the compliance function

CRISC Memory Aid

Enterprise Risk = Multiple Perspectives IT View = Technology Risk Compliance View = Regulatory Risk Third Party = Independent View Cross-Functional Team = Enterprise View Exam Rule: When CRISC asks for the BEST enterprise-wide view, choose the answer involving multiple stakeholders.

Q5: Explanation

Correct Answer: A

Effective enterprise risk management requires input from multiple stakeholders. An interdisciplinary team provides perspectives on strategic, operational, legal, regulatory, financial, and technology risks, creating the most complete view of risk exposure.

Option Analysis

A - **Correct** Enterprise risks often cross organizational boundaries. Business, IT, legal, compliance, operations, and other stakeholders each understand different risk exposures. Combining these viewpoints provides the most accurate assessment of enterprise risk. **B** - **Incorrect** Third-party assessments can be valuable and provide independent insight. However, external assessors may lack detailed knowledge of internal processes, culture, strategy, and business objectives. **C** - **Incorrect** IT assessments focus primarily on technology, cybersecurity, infrastructure, and application risks. Enterprise risk extends beyond technology and includes business, financial, operational, and regulatory concerns. **D** - **Incorrect** Compliance reviews focus on adherence to laws, regulations, policies, and standards. While important, compliance represents only one dimension of enterprise risk.

Q6: IT Risk Awareness Program

Question

Which is PRIMARY consideration when developing an IT risk awareness program?

A. Why technology risk is owned by IT
B. How technology risk can impact each attendee's area of business
C. How business process owners can transfer technology risk
D. Why technology risk is more difficult to manage

Q6: Explanation

Correct Answer: B

Stakeholders must understand how the IT-related risk impacts the overall business.

Option Analysis

- **A - Incorrect:** IT does not own technology risk; business owns it
- **B - Correct:** Business impact is the primary consideration
- **C - Incorrect:** Transferring risk is part of risk response, not awareness
- **D - Incorrect:** Difficulty of management is secondary to business impact

Q7: Risk Appetite Alignment

Question

It is MOST important that risk appetite is aligned with business objectives to ensure that:

- A Resources are directed toward areas of low risk tolerance
- B Major risk is identified and eliminated
- C IT and business goals are aligned
- D Risk strategy is adequately communicated

Q7: Explanation

Correct Answer: A

Risk appetite is the amount of risk that an enterprise is willing to take on in pursuit of value. Aligning it with business objectives allows an enterprise to evaluate and deploy valuable resources toward those objectives where the risk tolerance (for loss) is low.

Option Analysis

- **A - Correct:** Resources directed to low tolerance areas
- **B - Incorrect:** Risk elimination is rarely cost-effective
- **C - Incorrect:** Alignment affects more than IT and business
- **D - Incorrect:** Communication does not depend on alignment

Q7: Risk Appetite Alignment

Question

Executive management is reviewing the organization's risk appetite statement to ensure it supports strategic growth initiatives. Why is it MOST important that risk appetite be aligned with business objectives?

1. Resources can be prioritized toward objectives with the lowest tolerance for risk
2. Significant risks can be completely eliminated
3. Business and technology strategies remain synchronized
4. Risk management expectations can be communicated consistently

CRISC Memory Aid

Risk Appetite = How Much Risk We Want
Risk Tolerance = Allowed Variation
Risk Capacity = Maximum Survivable Risk
Strategy Drives Appetite
Appetite Drives Investment
Investment Drives Controls

Q7: Explanation

Correct Answer: A

Risk appetite defines the amount of risk the organization is willing to accept while pursuing business objectives. Alignment ensures management can allocate resources appropriately and focus attention on objectives where risk exposure exceeds acceptable levels.

Option Analysis

A – Correct Risk appetite helps management determine where resources, controls, and oversight should be concentrated. Objectives with lower tolerance for risk typically require stronger protection and greater investment.

B – Incorrect Risk management seeks to manage risk within acceptable levels, not eliminate all risk. Eliminating every significant risk would often be impractical and inconsistent with achieving business value.

C – Incorrect Alignment between business and technology goals is important, but this is only one benefit of risk appetite. The concept applies across the entire enterprise, not only IT.

D – Incorrect Communication is important, but communication alone does not explain why risk appetite must align with business objectives. The primary purpose is to support decision-making and resource allocation.

Q8: Weak Passwords and Unprotected Transmission

Question

Weak passwords and transmission over unprotected communication lines are examples of:

A. Vulnerabilities
B. Threats
C. Probabilities
D. Impacts

Q8: Explanation

Correct Answer: A

Vulnerabilities represent characteristics of information resources that may be exploited by a threat.

Option Analysis

- **A - Correct:** Weak passwords and unprotected transmission are vulnerabilities
- **B - Incorrect:** Threats are circumstances with potential to cause harm
- **C - Incorrect:** Probabilities represent likelihood of occurrence
- **D - Incorrect:** Impacts represent outcome of threat exploiting vulnerability

Q9: Quantitative Risk Analysis Drawback

Question

MOST significant drawback of using quantitative risk analysis instead of qualitative risk analysis is:

A. Lower objectivity
B. Greater reliance on expertise
C. Less management buy-in
D. Higher cost

Q9: Explanation

Correct Answer: D

Quantitative risk analysis is generally more complex and, therefore, more costly than qualitative risk analysis.

Option Analysis

- **A - Incorrect:** Neither method is fully objective
- **B - Incorrect:** Both require personnel with good business understanding
- **C - Incorrect:** Quantitative generally has better buy-in
- **D - Correct:** Quantitative is more complex and costly

Q9: Quantitative Risk Analysis

Question

An organization wants to perform a quantitative risk assessment for a new online banking platform. The risk practitioner notes that loss estimates, threat frequency data, and historical incident metrics must be collected before analysis can begin. What is the MOST significant challenge associated with using quantitative risk analysis?

- A Lower objectivity
- B Greater reliance on expertise
- C Reduced management support
- D Higher cost and effort

CRISC Memory Aid

Qualitative = Fast + Cheap + Subjective Quantitative = Slow + Expensive + Numerical Qualitative: High / Medium / Low Quantitative:

$ Value, ALE, SLE, ARO

Q9: Explanation

Correct Answer: D - Higher Cost and Effort

Quantitative risk analysis requires reliable data, statistical techniques, and significant analysis effort. Collecting and validating this information can be expensive and time-consuming, making quantitative approaches costlier than qualitative methods.

Option Analysis

A - **Incorrect** Quantitative analysis is generally considered more objective because it relies on numerical estimates and measurable criteria. Qualitative analysis is typically more dependent on judgment. **B** - **Incorrect** Both qualitative and quantitative approaches require experienced personnel. The difference is that quantitative analysis requires more detailed data collection and modeling. **C** - **Incorrect** Management often prefers quantitative results because financial impacts and loss estimates can be expressed in business terms. **D** - **Correct** Quantitative methods require historical loss information, probability estimates, asset valuations, and detailed analysis. Obtaining and maintaining this information increases cost, complexity, and effort.

Q10: Risk Scenario Analysis Purpose

Question

Risk scenarios are analyzed to determine:

A. Strength of controls
B. Likelihood and impact
C. Current risk profile
D. Scenario root cause

Q10: Explanation

Correct Answer: B

Risk scenarios are descriptions of events that can lead to a business impact and are evaluated to determine the likelihood and impact should the event occur.

Option Analysis

- **A - Incorrect:** Control strength is determined after controls are in place
- **B - Correct:** Likelihood and impact are the key assessments
- **C - Incorrect:** Risk profile is identification of current risk concerns
- **D - Incorrect:** Root cause is not part of risk scenario process

Q11: Risk Ownership of Critical System

Question

The risk to an information system that supports a critical business process is owned by:

A. IT director
B. Senior management
C. Risk management department
D. System users

Q11: Explanation

Correct Answer: B

Senior management is responsible for the acceptance and mitigation of all risk.

Option Analysis

- **A - Incorrect:** IT director manages systems on behalf of business owners
- **B - Correct:** Senior management owns risk
- **C - Incorrect:** Risk management determines and reports on risk but does not own it
- **D - Incorrect:** System users use system properly but do not own risk

Q12: Periodic Risk Assessment Reason

Question

PRIMARY reason risk assessments should be repeated at regular intervals is:

A. Omissions in earlier assessments can be addressed
B. Periodic assessments allow various methodologies
C. Business threats are constantly changing
D. They help raise risk awareness among staff

Q12: Explanation

Correct Answer: C

As business objectives and methods change, the nature and relevance of threats also change. This is the primary reason to conduct periodic risk assessments.

Option Analysis

- **A - Incorrect:** This is a benefit but not the primary reason
- **B - Incorrect:** Organizations strive to improve but this is not primary
- **C - Correct:** Threats constantly change
- **D - Incorrect:** Risk awareness is a minor benefit

Q13: Measuring Risk Management Development

Question

Which BEST assists in measuring existing level of development of risk management processes against desired state?

A. Capability maturity model (CMM)
B. Risk management audit reports
C. Balanced scorecard
D. Enterprise security architecture

Q13: Explanation

Correct Answer: A

The capability maturity model (CMM) grades processes on a scale of 0 to 5, based on their maturity. It is commonly used by entities to measure their existing state and then to determine the desired one.

Option Analysis

- **A - Correct:** CMM measures current vs desired state
- **B - Incorrect:** Audit reports offer limited view
- **C - Incorrect:** Balanced scorecard measures implementation of strategy
- **D - Incorrect:** Enterprise security architecture explains business strategy view

Q14: Identifying Control Deficiencies

Question

Which BEST helps identify information systems control deficiencies?

- A Gap analysis
- B Current IT risk profile
- C IT controls framework
- D Countermeasure analysis

Q14: Explanation

Correct Answer: A

Controls are deployed to achieve desired control objectives based on risk assessments and business requirements. The gap between desired control objectives and actual IS control design and operational effectiveness identifies control deficiencies.

Option Analysis

- **A - Correct:** Gap analysis identifies deficiencies
- **B - Incorrect:** Risk profile does not expose gaps
- **C - Incorrect:** Framework is generic without current state info
- **D - Incorrect:** Only identifies countermeasure deficiencies

Q15: Statistical Methods Risk Analysis

Question

Deriving likelihood and impact of risk scenarios through statistical methods is MOST LIKELY associated with which type of risk analysis?

A. Risk scenario
B. Qualitative
C. Quantitative
D. Semiquantitative

Q15: Explanation

Correct Answer: C

The essence of quantitative risk assessment is to derive the likelihood and impact of risk scenarios based on statistical methods and data.

Option Analysis

- **A - Incorrect:** Scenario analysis includes several methods
- **B - Incorrect:** Qualitative uses experiential measures
- **C - Correct:** Quantitative uses statistical methods
- **D - Incorrect:** Semiquantitative assigns values to qualitative ratings

Q16: Reviewing Risk Analysis Results

Question

Which review is BEST suited for review of IT risk analysis results before sending to management?

A. Internal audit review
B. Peer review
C. Compliance review
D. Risk policy review

Q16: Explanation

Correct Answer: B

It is effective, efficient and good practice to perform a peer review of IT risk analysis results before sending them to management.

Option Analysis

- **A - Incorrect:** Audit is independent assurance
- **B - Correct:** Peer review is good practice
- **C - Incorrect:** Compliance reviews measure conformance
- **D - Incorrect:** Policy review may change content but isn't a review method

Q17: Risk Cannot Be Sufficiently Mitigated

Question

When risk cannot be sufficiently mitigated through manual or automatic controls, which option BEST protects from potential financial impact?

A. Insuring against the risk
B. Updating IT risk register
C. Improving staff training
D. Outsourcing related process

Q17: Explanation

Correct Answer: A

An insurance policy can compensate the enterprise monetarily for the impact of the risk by transferring the risk to the insurance company.

Option Analysis

- **A - Correct:** Insurance transfers financial risk
- **B - Incorrect:** Updating register doesn't change risk
- **C - Incorrect:** Staff training may reduce but not completely mitigate
- **D - Incorrect:** Outsourcing does not necessarily remove risk

Q18: Risk Mitigation Must Reduce

Question

To be effective, risk mitigation MUST reduce the:

A. Residual risk

B. Inherent risk

C. Frequency of a threat

D. Impact of a threat

Q18: Explanation

Correct Answer: A

The objective of risk reduction is to reduce the residual risk to levels below the enterprise's risk tolerance level.

Option Analysis

- **A - Correct:** Residual risk must be reduced to acceptable level
- **B - Incorrect:** Reduction of inherent risk is not the goal
- **C - Incorrect:** Can focus on reducing either frequency or impact
- **D - Incorrect:** Can focus on reducing either frequency or impact

Q19: Best Control to Prevent Unauthorized Access

Question

BEST control to prevent unauthorized access to information is user:

- A Accountability
- B Authentication
- C Identification
- D Access rules

Q19: Explanation

Correct Answer: B

Authentication verifies the user's identity and the right to access information according to the access rules.

Option Analysis

- **A - Incorrect:** Accountability maps activity back to responsible party
- **B - Correct:** Authentication verifies identity
- **C - Incorrect:** Identification without authentication does not grant access
- **D - Incorrect:** Access rules without identification and authentication do not grant access

Q20: Controlling Access to Sensitive Information

Question

Which control BEST protects from unauthorized individuals gaining access to sensitive information?

- A Using a challenge response system
- B Forcing periodic password changes
- C Monitoring unsuccessful login attempts
- D Providing access on a need-to-know basis

Q20: Explanation

Correct Answer: D

Physical or logical system access should be assigned on a need-to-know basis (legitimate business requirements) and in ways that incorporate least privilege and segregation of duties.

Option Analysis

- **A - Incorrect:** Challenge response doesn't address access design
- **B - Incorrect:** Password changes don't guarantee appropriate access
- **C - Incorrect:** Monitoring doesn't address appropriate access rights
- **D - Correct:** Need-to-know basis is fundamental

Q21: Best Defense Against Phishing

Question

Which defense is BEST to use against phishing attacks?

- A Intrusion detection system
- B Spam filters
- C End-user awareness
- D Application hardening

Q21: Explanation

Correct Answer: C

Phishing attacks are a type of social engineering attack and are best defended by end-user awareness training.

Option Analysis

- **A - Incorrect:** IDS doesn't protect against phishing
- **B - Incorrect:** Spam filters are not as effective as user awareness
- **C - Correct:** User awareness is the best defense
- **D - Incorrect:** Application hardening doesn't protect against phishing

Q22: Stakeholders in Risk Response Review

Question

When responding to identified risk, MOST important stakeholders involved in reviewing risk response options are:

A. Information security managers
B. Internal auditors
C. Incident response team members
D. Business managers

Q22: Explanation

Correct Answer: D

Business managers are accountable for managing the associated risk and will determine what actions to take based on the information provided by others, which may include collaboration with and support from IT security managers.

Option Analysis

- **A - Incorrect:** Security managers understand technical aspects but don't decide
- **B - Incorrect:** Risk response is not a function of internal audit
- **C - Incorrect:** Incident response team responds to incidents
- **D - Correct:** Business managers are accountable

Q23: Designing Information System Controls

Question

Which should be considered FIRST when designing information system controls?

- A Organizational strategic plan
- B Existing IT environment
- C Present IT budget
- D IT strategic plan

Q23: Explanation

Correct Answer: A

Review of the enterprise's strategic plan is the first step in designing effective IS controls that would fit the enterprise's long-term plans.

Option Analysis

- **A - Correct:** Strategic plan is the starting point
- **B - Incorrect:** Useful but not the first task
- **C - Incorrect:** Budget is one component of strategic plan
- **D - Incorrect:** IT strategic plan exists to support enterprise's strategic plan

Q24: Residual Risk Calculation Basis

Question

Residual risk can be accurately calculated on the basis of:

A. Threats and vulnerabilities
B. Inherent risk and control risk
C. Compliance risk and reputation
D. Risk governance and risk response

Q24: Explanation

Correct Answer: B

Inherent risk multiplied by control risk is the formula to calculate residual risk.

Option Analysis

- **A - Incorrect:** Threat/vulnerability are elements of inherent risk
- **B - Correct:** Inherent risk $\times$ control risk $=$ residual risk
- **C - Incorrect:** Compliance risk is not a basis for calculation
- **D - Incorrect:** These are risk domains, not elements

Q25: Maintaining KRIs

Question

MOST important reason to maintain key risk indicators (KRIs) is that:

A. Complex metrics require fine-tuning
B. Threats and vulnerabilities change over time
C. Risk reports need to be timely
D. They help to avoid risk

Q25: Explanation

Correct Answer: B

Threats and vulnerabilities change over time, and KRI maintenance ensures that KRIs continue to effectively capture these changes.

Option Analysis

- **A - Incorrect:** Fine-tuning is secondary to capturing changes
- **B - Correct:** Threats and vulnerabilities change over time
- **C - Incorrect:** Timeliness is a business requirement
- **D - Incorrect:** Risk avoidance is one risk response

Q26: Measuring Operational Effectiveness

Question

Which is BEST measure of operational effectiveness of risk management process capabilities?

A. Key performance indicators (KPIs)
B. Key risk indicators (KRIs)
C. Base practices
D. Metric thresholds

Q26: Explanation

Correct Answer: A

Key performance indicators (KPIs) are assessment indicators that support judgment regarding the performance of a specific process.

Option Analysis

- **A - Correct:** KPIs measure process performance
- **B - Incorrect:** KRIs provide insights into potential risk
- **C - Incorrect:** Base practices need work products for evidence
- **D - Incorrect:** Thresholds are decision points

Q27: Data Extraction Forecasting

Question

During data extraction, total transactions per year was forecasted by multiplying monthly average by twelve. This is considered:

- A. A controls total
- B. Simplistic and ineffective
- C. A duplicates test
- D. A reasonableness test

Q27: Explanation

Correct Answer: D

Reasonableness tests make certain assumptions about the information as the basis for more elaborate data validation tests.

Option Analysis

- **A - Incorrect:** Does not ensure all transactions extracted
- **B - Incorrect:** Reasonableness test is valid foundation
- **C - Incorrect:** Does not identify duplicate transactions
- **D - Correct:** This is a reasonableness test

Q28: Testing Access Management Effectiveness

Question

BEST test for confirming effectiveness of system access management process is to map:

A. Access requests to user accounts
B. User accounts to access requests
C. User accounts to HR records
D. Vendor database to user accounts

Q28: Explanation

Correct Answer: B

Mapping user accounts to access requests confirms that all existing accounts have been approved.

Option Analysis

- **A - Incorrect:** Confirms requests processed but not unapproved accounts
- **B - Correct:** Confirms all accounts have been approved
- **C - Incorrect:** Confirms accounts tied to employees only
- **D - Incorrect:** Flawed because it doesn't consider unapproved accounts

Q29: Firewall Compliance Assurance

Question

Which provides BEST assurance that a firewall is configured in compliance with enterprise's security policy?

A. Reviewing actual procedures
B. Interviewing firewall administrator
C. Reviewing parameter settings
D. Reviewing log file for recent attacks

Q29: Explanation

Correct Answer: C

A review of the parameter settings provides a good basis for comparison of the actual configuration to the security policy and reliable audit evidence documentation.

Option Analysis

- **A - Incorrect:** Procedures show how it should be managed, not compliance
- **B - Incorrect:** Interview provides overview, not confirmation
- **C - Correct:** Parameter settings show actual configuration
- **D - Incorrect:** Log review shows logging is enabled, not configuration

Q30: Verifying Control Effectiveness

Question

One way to verify control effectiveness is by determining:

- A Its reliability
- B Whether it is preventive or detective
- C Capability of providing notification of failure
- D Test results of intended objectives

Q30: Explanation

Correct Answer: D

Control effectiveness requires a process to verify that the control process worked as intended and meets the intended control objectives.

Option Analysis

- **A - Incorrect:** Weak controls can be highly reliable
- **B - Incorrect:** Control type doesn't determine effectiveness
- **C - Incorrect:** Notification of failure doesn't determine strength
- **D - Correct:** Test results verify intended objectives

Q31: Correlation Tools for Trend Analysis

Question

Tools that correlate information from multiple systems to improve trend analysis are MOST likely applied to:

A. Transaction data
B. Configuration settings
C. System changes
D. Process integrity

Q31: Explanation

Correct Answer: A

Transaction data tends to be difficult to analyze for trends across multiple systems because of sheer volume. Therefore, correlation engines are often used to analyze the data to see trends that otherwise might not be apparent.

Option Analysis

- **A - Correct:** Transaction data benefits from correlation
- **B - Incorrect:** Configuration settings are compared to predefined values
- **C - Incorrect:** System changes rarely benefit from trend analysis
- **D - Incorrect:** Process integrity not typically associated with trend analysis

Q32: Ensuring Outsourced Compliance

Question

Most effective way to ensure outsourced service providers comply with enterprise information security policy?

- A Periodic audits
- B Security awareness training
- C Penetration testing
- D Service level monitoring

Q32: Explanation

Correct Answer: A

Regular audits can identify gaps in information security compliance.

Option Analysis

- **A - Correct:** Audits ensure compliance
- **B - Incorrect:** Training increases awareness but less effective
- **C - Incorrect:** Penetration testing identifies vulnerabilities
- **D - Incorrect:** Service monitoring identifies operational issues

Q33: Risk Appetite and Tolerance Definition

Question

Risk appetite is defined as:

- A. The amount of risk an enterprise can tolerate without existence being questioned
- B. The amount of risk an enterprise is willing to accept in pursuit of its mission
- C. The acceptable level of variation management is willing to allow
- D. The maximum loss an enterprise can absorb

Q33: Explanation

Correct Answer: B

Risk appetite is defined as the amount of risk, on a broad level, that an entity is willing to accept in pursuit of its mission.

Option Analysis

- **A - Incorrect:** This is risk capacity
- **B - Correct:** This is the definition of risk appetite
- **C - Incorrect:** This is risk tolerance
- **D - Incorrect:** This is risk capacity

Q34: Risk Tolerance Example

Question

Risk tolerance is best described as:

A. The maximum risk an enterprise can take
B. The acceptable level of deviation from risk appetite
C. The complete elimination of risk
D. The transfer of risk to a third party

Q34: Explanation

Correct Answer: B

Risk tolerance is defined as the acceptable level of variation that management is willing to allow for any particular risk as the enterprise pursues its objectives.

Option Analysis

- **A - Incorrect:** This is risk capacity
- **B - Correct:** Tolerance is acceptable deviation
- **C - Incorrect:** Risk cannot be completely eliminated
- **D - Incorrect:** This is risk transfer

Q35: Risk Culture Symptoms

Question

Which is a symptom of an inadequate or problematic risk culture?

- A Open communication about risk
- B Clear understanding of risk appetite
- C Overconfidence in ability to manage risk
- D Regular risk reporting to management

Q35: Explanation

Correct Answer: C

Overconfidence in ability to manage risk is a symptom of problematic risk culture.

Option Analysis

- **A - Incorrect:** Open communication is healthy
- **B - Incorrect:** Clear understanding is positive
- **C - Correct:** Overconfidence indicates problematic culture
- **D - Incorrect:** Regular reporting is good practice

Q36: Confidentiality Breach

Question

Which is an example of a breach of confidentiality?

- A Data being modified by unauthorized user
- B Data being unavailable when needed
- C Data being disclosed to unauthorized recipient
- D Data being destroyed

Q36: Explanation

Correct Answer: C

A breach of confidentiality means the improper disclosure of information to a recipient not authorized access by the information owner.

Option Analysis

- **A - Incorrect:** This is a breach of integrity
- **B - Incorrect:** This is a breach of availability
- **C - Correct:** Unauthorized disclosure is confidentiality breach
- **D - Incorrect:** This is a breach of integrity/availability

Q37: CIA Triad Trade-off

Question

Increasing confidentiality typically:

A. Increases availability

B. Decreases processing time

C. Increases processing time and may reduce availability

D. Has no effect on availability

Q37: Explanation

Correct Answer: C

Increasing confidentiality typically increases processing time, which reduces availability. There are trade-offs between the three principles.

Option Analysis

- **A - Incorrect:** Usually decreases availability
- **B - Incorrect:** Usually increases processing time
- **C - Correct:** Trade-off between confidentiality and availability
- **D - Incorrect:** There is typically an effect

Q38: OCTAVE Methodology

Question

OCTAVE focuses primarily on:

A. Technical vulnerabilities only
B. Critical assets and risk to those assets
C. Financial risk quantification
D. Compliance requirements

Q38: Explanation

Correct Answer: B

OCTAVE focuses on critical assets and the risk to those assets using a comprehensive, systematic, context-driven and self-directed evaluation approach.

Option Analysis

- **A - Incorrect:** Not focused only on technical vulnerabilities
- **B - Correct:** Focuses on critical assets
- **C - Incorrect:** Not financial quantification
- **D - Incorrect:** Not primarily compliance

Q39: Phases of OCTAVE

Question

Phase 1 of OCTAVE involves:

A. Identifying infrastructure vulnerabilities
B. Building asset-based threat profiles
C. Developing security strategy
D. Implementing controls

Q39: Explanation

Correct Answer: B

Phase 1 of OCTAVE is to build asset-based threat profiles through organizational evaluation.

Option Analysis

- **A - Incorrect:** This is Phase 2
- **B - Correct:** Phase 1 builds threat profiles
- **C - Incorrect:** This is Phase 3
- **D - Incorrect:** This follows OCTAVE

Q40: Fault Tree Analysis

Question

Fault tree analysis is best described as:

A. Forward-looking, bottom-up model

B. Top-down analysis starting with an event

C. Statistical inference method

D. Delphi consensus technique

Q40: Explanation

Correct Answer: B

A fault tree analysis starts with an event and examines possible means for the event to occur (top-down) and displays these results in a logical tree diagram.

Option Analysis

- **A - Incorrect:** This is event tree analysis
- **B - Correct:** Top-down analysis starting with event
- **C - Incorrect:** This is Bayesian analysis
- **D - Incorrect:** This is Delphi method

Q41: Monte Carlo Analysis

Question

Monte Carlo analysis is used to:

A. Eliminate risk entirely
B. Establish aggregate variation in a system
C. Identify single points of failure
D. Document security policies

Q41: Explanation

Correct Answer: B

Monte Carlo simulation is used to establish the aggregate variation in a system resulting from variations in the system, for a number of inputs, where each input has a defined distribution.

Option Analysis

- **A - Incorrect:** Cannot eliminate risk entirely
- **B - Correct:** Establishes aggregate variation
- **C - Incorrect:** Not for identifying SPOFs
- **D - Incorrect:** Not for documentation

Q42: Delphi Method

Question

Delphi method leverages:

A. Expert opinion through multiple questionnaire rounds
B. Statistical analysis of historical data
C. Automated vulnerability scanning
D. Document review

Q42: Explanation

Correct Answer: A

The Delphi method leverages expert opinion received using two or more rounds of questionnaires. After each round, results are summarized and communicated by a facilitator.

Option Analysis

- **A - Correct:** Expert opinion through multiple rounds
- **B - Incorrect:** Not statistical analysis
- **C - Incorrect:** Not automated scanning
- **D - Incorrect:** Not document review

Q43: Cost-Benefit Analysis Purpose

Question

Cost-benefit analysis is used to:

A. Justify expense of control implementation
B. Calculate annual loss expectancy
C. Determine risk appetite
D. Identify threats

Q43: Explanation

Correct Answer: A

Cost-benefit analysis is used to justify the expense associated with the implementation of controls. The expenditure on a control cannot be justified if the benefit realized is less than the cost.

Option Analysis

- **A - Correct:** Justifies control expense
- **B - Incorrect:** ALE is calculated differently
- **C - Incorrect:** Risk appetite is management decision
- **D - Incorrect:** Threats are identified through risk identification

Q44: Risk Transfer Example

Question

Risk transfer is best exemplified by:

A. Purchasing insurance
B. Implementing a firewall
C. Conducting user training
D. Creating a policy

Q44: Explanation

Correct Answer: A

Risk transfer is a decision to reduce loss by having another organization incur the cost. The most common example of risk transfer is the purchasing of insurance.

Option Analysis

- **A - Correct:** Insurance transfers risk
- **B - Incorrect:** Firewall is mitigation
- **C - Incorrect:** Training is mitigation/awareness
- **D - Incorrect:** Policy is administrative control

Q45: When to Accept Risk

Question

Risk should be accepted when:

A. It falls within organizational risk appetite

B. It exceeds risk capacity

C. Controls are available

D. The cost of controls is low

Q45: Explanation

Correct Answer: A

Risk that falls within the organizational risk appetite should be accepted. The decision to accept risk is made according to the risk appetite and risk tolerance set by senior management.

Option Analysis

- **A - Correct:** Within risk appetite
- **B - Incorrect:** Cannot exceed risk capacity
- **C - Incorrect:** If controls available, consider mitigation
- **D - Incorrect:** Low cost may justify mitigation

Q46: Risk Avoidance

Question

Risk avoidance means:

A. Transferring risk to insurance
B. Exiting activities that give rise to risk
C. Reducing risk through controls
D. Accepting risk without action

Q46: Explanation

Correct Answer: B

Risk avoidance means exiting the activities or conditions that give rise to risk. It is the choice that remains when no other response is adequate.

Option Analysis

- **A - Incorrect:** This is risk transfer
- **B - Correct:** Exiting risk-causing activities
- **C - Incorrect:** This is risk mitigation
- **D - Incorrect:** This is risk acceptance

Q47: Symmetric Encryption

Question

Symmetric encryption uses:

A. Two mathematically related keys
B. The same secret key for encryption and decryption
C. Public and private key pairs
D. Digital certificates

Q47: Explanation

Correct Answer: B

Symmetric key cryptography occurs when an encryption algorithm uses the same secret key to encrypt the plaintext into ciphertext and to decrypt the ciphertext back into plaintext.

Option Analysis

- **A - Incorrect:** This is asymmetric encryption
- **B - Correct:** Same key for both operations
- **C - Incorrect:** This is asymmetric encryption
- **D - Incorrect:** Certificates are for identity verification

Q48: Digital Signature

Question

A digital signature provides:

A. Confidentiality only
B. Integrity and nonrepudiation
C. Availability only
D. Authentication only

Q48: Explanation

Correct Answer: B

A digital signature combines a hash function with asymmetric encryption to verify the author's identity. It provides integrity (message not changed) and nonrepudiation (sender cannot deny sending).

Option Analysis

- **A - Incorrect:** Does not provide confidentiality on its own
- **B - Correct:** Provides integrity and nonrepudiation
- **C - Incorrect:** Not related to availability
- **D - Incorrect:** Provides more than authentication

Q49: Asymmetric Encryption Advantage

Question

Asymmetric encryption's main advantage over symmetric is:

A. Faster processing speed
B. Easier key management for secure exchange
C. Lower computational requirements
D. Simpler implementation

Q49: Explanation

Correct Answer: B

Asymmetric algorithms overcome the weakness of scalability of symmetric key cryptography by allowing secure key exchange. The public key can be freely distributed, making key management easier.

Option Analysis

- **A - Incorrect:** Asymmetric is slower
- **B - Correct:** Easier key management
- **C - Incorrect:** Higher computational requirements
- **D - Incorrect:** More complex implementation

Q50: KRI Sensitivity

Question

A KRI that generates too many false positives should be adjusted for:

A. Sensitivity
B. Timeliness
C. Frequency
D. Reliability

Q50: Explanation

Correct Answer: A

KRIs that report on data points that cannot be controlled or are not alerting at the correct time should be adjusted (optimized) to be more precise, relevant or accurate. Sensitivity should be adjusted to reduce false positives.

Option Analysis

- **A - Correct:** Sensitivity affects false positives
- **B - Incorrect:** Timing is about when alerts occur
- **C - Incorrect:** Frequency is how often measured
- **D - Incorrect:** Reliability is correlation with risk

Q51: KPI and KRI Relationship

Question

KPIs and KRIs are often used together because:

A. They measure the same thing

B. KPIs identify underperformance; KRIs provide early warnings

C. KRIs replace KPIs in mature organizations

D. They are independent and not related

Q51: Explanation

Correct Answer: B

KPIs help to identify underperforming aspects of the organization, while KRIs provide early warnings of increased risk. Failing to meet performance goals is a risk, so the two can be used together.

Option Analysis

- **A - Incorrect:** They measure different things
- **B - Correct:** Complementary purposes
- **C - Incorrect:** KRIs don't replace KPIs
- **D - Incorrect:** They are related

Q52: KRI Maintenance Frequency

Question

KRIs should be evaluated:

A. Annually
B. Only when incidents occur
C. On a regular basis
D. Never after implementation

Q52: Explanation

Correct Answer: C

Because the organization's internal and external environments are constantly changing, the set of KRIs needs to be evaluated on a regular basis to verify that each KRI remains properly related to the risk appetite and tolerance levels.

Option Analysis

- **A - Incorrect:** May need more frequent evaluation
- **B - Incorrect:** Should be proactive, not reactive
- **C - Correct:** Regular evaluation is needed
- **D - Incorrect:** Must be maintained over time

Q53: SIEM Primary Function

Question

SIEM systems primarily:

A. Correlate data from multiple sources
B. Store backup data
C. Manage user identities
D. Encrypt network traffic

Q53: Explanation

Correct Answer: A

SIEM systems are integrated data correlation tools that capture data from multiple sources and analyze system, application and network activity for possible security events.

Option Analysis

- **A - Correct:** Correlation of multiple data sources
- **B - Incorrect:** Not for backup storage
- **C - Incorrect:** Identity management is separate
- **D - Incorrect:** Not for traffic encryption

Q54: Log Review Challenges

Question

Common challenge with log review is:

A. Too much data to analyze effectively
B. Not enough data being collected
C. Logs being too expensive
D. Logs not being required

Q54: Explanation

Correct Answer: A

Common challenges relating to the effective use of logs include having too much data, difficulty in searching for relevant information, improper configuration, and modification or deletion of data before it is read.

Option Analysis

- **A - Correct:** Data volume is a challenge
- **B - Incorrect:** Often there is too much data
- **C - Incorrect:** Cost is not the primary challenge
- **D - Incorrect:** Logs are typically required

Q55: Control Monitoring Purpose

Question

Purpose of control monitoring is to verify:

A. Whether the control is working
B. Whether the control is effectively addressing the risk
C. Whether staff is following procedures
D. Whether logs are being reviewed

Q55: Explanation

Correct Answer: B

Because the purpose of a control is to mitigate a risk, the purpose of control monitoring is to verify whether the control is effectively addressing the risk, not to see whether the control itself is working.

Option Analysis

- **A - Incorrect:** This is just operational status
- **B - Correct:** Verify effectiveness against risk
- **C - Incorrect:** This is compliance monitoring
- **D - Incorrect:** This is log review, not control monitoring

CRISC Key Takeaways from Review Manual

Essential Concepts

- Risk appetite = amount of risk willing to accept in pursuit of mission
- Risk tolerance = acceptable level of deviation from appetite
- Risk capacity = maximum risk before existence is questioned
- C MM: 5 levels from Incomplete to Optimized
- CIA: Confidentiality, Integrity, Availability
- Digital signatures provide integrity and nonrepudiation

CRISC Key Takeaways (continued)

More Essential Concepts

- Risk assessment = identify and evaluate risk and potential effects
- Risk response options: Accept, Mitigate, Transfer, Avoid
- Residual risk = Inherent risk - Controls
- KRIs predict risk; KPIs measure performance
- 3 LoD: Operational management, Risk oversight, Audit

Final Advice

Exam Preparation

Remember:

- Understand the *why* behind each concept
- Know the difference between risk appetite, tolerance, and capacity
- Understand the risk management life cycle (Identify, Assess, Respond, Monitor)
- Practice scenario-based questions
- Use the ISACA mindset - choose the MOST appropriate answer

Good Luck on Your CRISC Exam!